Internal and External Cyber Threats and Precautions

Posted by: RaiDeiNz

March 7, 2021

Summary of The Article

The purpose of this report is mainly to explain what internal and external threats are. However, since the world of informatics is constantly evolving, ensuring appropriate adaptation to the innovations in the sector in order to raise a general awareness of the subject; It has been prepared with the aim of introducing the basic concepts of information / data security management and information security standards to the reader. It starts with the explanation of data protection principles and ends with an explanation of what internal and external threats are, their types and precautions.

Summary of The Article **1**

PREAMBLE **4**

1-1. Complex IT and the Changing Threat Concept 4

1-2. Information Security Standards / Frameworks 4

1-2-1. ISO/IEC 27000 Series 5

1-2-2. COBIT (ISACA) 5

1-2-3. PCI-DSS 5

1-2-4. ITIL v3 5

1-2-5. SoX, NIST, HIPAA 5

1-2-6. CMMI, PMBOK, PRINCE, COSO 5

1-3. Information Security Management Basic Concepts 5

1-3-1. Asset 5

1-3-2. Vulnerability 6

1-3-3. Threat 6

1-3-4. Risk 6

1-3-5. Possibility 6

1-3-6. Effect 6

INTERNAL THREATS **6**

2-1. Preamble 6

2-2. Definition 6
2-3. Internal Threats 7
2-4. Methods of Protection from Internal Threats 7
2-5. Training Subjects That Can Be Given to Employees 7
2-5-1. Phone Fraud 8
2-5-2. VPN Security 8
2-5-3. Social Media Security 8
2-5-4. Personal Hardware Security 8
2-5-6. Password Security 8
2-5.7 Phishing and Identity Theft 9
2-5-8 E-mail Fraud 10
2-5-9 SMS Phishing Attack / Smishing 10

EXTERNAL THREATS 11
3-1. Preamble 11
3-2. Definition 11
3-3. External Threats 12
3-3-1. DDoS 12
3-3-2. Session Hijacking 12
3-3-3. Drive-by Attack 12
3-3-4. Password Attack 13
a. Phishing 13
b. Man-in-The-Middle Attack 13
c. Brute Force Attack 13
d. Dictionary Attack 13
e. Credential Stuffing 14
f. Keyloggers 14
3-3-5. Spear Phishing 14
3-3-6. Ransomware 14
3-3-7. Malware 14
3-3-8. Malvertising 14
3-3-9. APT 15
3-4. Methods of Protection from External Threats 16

PEOPLE WHO MAY BE TARGET OF INTERNAL AND EXTERNAL THREATS 16
4-1. Persons 16
4-2. Institutions and Companies 16
4-3. Countries 16
4-4. Unions and Groups 16
4-5. World and Beyond 16

1. PREAMBLE

Before starting this report, it is necessary to look a little further back at the chronological development of events. Question: Why are standard and framework models developed in information technologies?

For example, let's understand why the TCP / IP and OSI models were created in the first place, with little reference to it. In the beginning, there was no concept of standardization. The manufacturers followed their own methodology and as a result, different systems made by different manufacturers were completely incompatible when it comes to networking. For this reason, the TCP/IP model was introduced by the US Department of Defense in 1982 to provide a standard. The aim was to resolve inconsistency problems and to create a common network.

1-1. Complex IT and the Changing Threat Concept

The complexity of IT infrastructures and services for institutions is increasing day by day; Confidentiality, Integrity, Availability, Access Verification, Encryption, Redundancy, etc. core values are constantly changing.

The developing world of informatics, diversified services, and technological innovations are seriously changing the concepts and perceptions of threat.

While we, as end-users, cannot keep up with the pace of this change, we cannot expect threats to remain constant. For this reason, everyone in the IT world should have an idea about the products and digital innovations they use.

1-2. Information Security Standards / Frameworks

Along with the changing world of informatics, some countries and companies have created some standards to prevent the risks to be encountered, as well as the existing cyber threats and the emergence of new ones.

1-2-1. ISO/IEC 27000 Series

To keep information assets safe; It enables organizations of all types to manage the security of assets such as financial information, intellectual property, employee information, or information entrusted by third parties.

1-2-2. COBIT (ISACA)

COBIT enables managers, auditors, and Information Technology users to transform business goals into computing goals, bring together the necessary resources and processes to achieve these goals, while also enabling effective use of information technology infrastructures.

1-2-3. PCI-DSS

It is an information security standard for organizations using credit cards and smart cards.

1-2-4. ITIL v3

It is a detailed application framework for information technology service management (ITSM) that focuses on aligning information technology services with the needs of the business.

1-2-5. SoX, NIST, HIPAA

These are Standards that Create Solutions for Companies and Industries.

1-2-6. CMMI, PMBOK, PRINCE, COSO

Standards of Software, Project, Development Tools etc.

1-3. Information Security Management Basic Concepts

Good analysis of assets and threats is the cornerstone of our risk management.

There are some concepts that the standards and frameworks created for information security are based on in their formation. If we can properly manage the methodology of these concepts for ourselves, we will be relatively safe from these threats. These concepts are:

1-3-1. Asset

Something that is owned and of value to us.

1-3-2. Vulnerability

The openness or weakness that can be used to create a potential threat.

1-3-3. Threat

Any action that may result in harm.

1-3-4. Risk

The occurrence of the threat arising from the vulnerability.

1-3-5. Possibility

The possibility of a risk.

1-3-6. Effect

The result when a risk occurs.

2. INTERNAL THREATS

2-1. Preamble

According to a 2017 survey, 72% of company employees tend to share company information. And 65% of these people want to share this data, even though they are aware that the data that needs to be protected is within their responsibility…

2-2. Definition

A threat originating from within the industry, institution or government firms that causes abuse due to dissatisfaction with an employee's promotion or sudden dismissal is known as an internal Cyber Threat. This type of threat is after the employee's complaints about his mental thoughts towards his place of work.

In addition, since personnel are allowed to access the content of the workplace; this, When negative thoughts arise in one's mind, it means that a major data breach can occur.

In a large or medium-sized business, it is not possible to read everyone's mindset and work accordingly. Sometimes it can be hard to believe that an employee will willingly sabotage his or her company, and while it sometimes happens on purpose, it is often purely accidental. The main internal cyber threats are:

2-3. Internal Threats

- Leaking of data by an employee after being fired or given leave.
- Selling company data for financial gain.
- Stealing of trade secrets.

- Deceiving people working from home with vishing (company employee ID) fraud.
- Employee taking company data to a new employer to gain competitive advantage.
- The leaking by employees of customer data.
- Seducing/Charming an employee by offering a bribe. (Bribery is not always monetary.)
- Accidentally sending an email to the wrong person.
- The vulnerability of the employee's system who accidentally misconfigured their access privileges.
- Granting high access to the wrong employee when setting access privileges.
- Sending company data to a personal email account.
- Installing an external memory that it does not own on company hardware for any purpose, etc.

2-4. Methods of Protection from Internal Threats

- Monitor files, email, and activity in your core data sources.
- Determine where your sensitive data/files should be located.
- Determine who has access to this data and who should have access to it.
- Remove data access permissions/accounts of your ex-employees.
- Randomly generate new employees' passwords without a specific algorithm. (The algorithms are discoverable.
- Review and update all your software.
- Publish a security policy in line with the risk analysis for your company.
- Redound your employees into a social community, make it possible to be a fellow, and give training.

2-5. Training Subjects That Can Be Given to Employees

Developments in the world of informatics cause new threats to occur constantly. Gaining awareness about any subject will only protect you from threats on that subject. Therefore, people need to constantly improve themselves. This detail is given because the entire article has been prepared based on raising awareness.

The knowledge that a company employee should acquire is as follows:

2-5-1. Phone Fraud

Nowadays, phone numbers can be shown as another number with methods such as "Caller ID Spoofing". The caller may also appear to be calling from your company's number. Or you can get a message from this number. To avoid such vishing traps, do not share your sensitive data directly.

2-5-2. VPN Security

VPN (Virtual Private Network, imagable as a tunnel) is essentially a technology developed to provide secure and encrypted data transmission within the company and also to interconnect company networks. With the pandemic, many people had to connect to their institution with a VPN. When you create a VPN on your device, additional identity verification, you must use options. Also, a VPN connection in your local network must be used on a single device.

2-5-3. Social Media Security

Although you are using the internet safely, your friends may not be using it as consciously as you. For this reason, it is necessary to pay special attention to every link shared on social media, even if it comes from your friends.

2-5-4. Personal Hardware Security

Although we have set passwords for our devices, we leave the session open from time to time and get up from the computer; Sometimes we leave the phone on the table and get up to the sink because we have a friend at the table in a restaurant. This is a common behavior even if we don't do it. However, a phone can be easily seized with an sd-card. A permanent backdoor can be created on a computer in 2 minutes without any software. With software that uses a keyboard framework that is written into a USB device, this time can be 5-8 seconds.

2-5-6. Password Security

Enigma is a primitive encryption device. And the Colossus computer, which was also produced as a primitive password cracker, changed the course of the 2nd world war.

The most common situation is the insecure and simple creation of passwords. When creating a password, we must make sure that it is complex.

The most common mistake people make is in applications where it is necessary to create complex passwords; The uppercase character is usually the first letter, the number is 123, and the special character is a dot due to its close to the enter key(This is the case with Turkish

keyboards. Keyboard localization changes this situation.). Such passwords are easy to guess, although not as simple as others.

Nor should we be inspired by the objects around us when creating a password! In addition, other things to know about "Password Security" are as follows:

- **Protection of Passwords**
  Pins and passwords should not be shared even under any obligation. It is quite possible to come across someone who tells the marketer to enter the card code while bagging the grocery products. (In some cases, for RFID and NFC you must also protect the card itself.)

- **Not Reusing a Previously Created Password For Another App**
  As observed in the recent 'kitapyurdu' (An enterprise that provides online library services and book sales in Turkey.) attack, users both created simple passwords and used the same username and password when registering for different systems. It is said that among them is a former Deputy. The possibility that they can access the system and steal state secrets with the address fat**.ci**ci@*.gov.tr, if their password is the same, is a frightening reality.

- **Passwords Should Be at Least Moderately Secure**
  It's a good approach to use all allowed ASCII table characters when creating a password. Passwords must be at least 12-16 characters. Passwords should contain numbers or a series of numbers, upper and lower case random letters, and special characters. A password should look at least like this :
  It-$h0uLd~b3.l1ke_7his!

2-5.7 Phishing and Identity Theft

Phishing attacks are an extremely popular online attack method. They are prepared by sending extremely realistic e-mails to people, imitating institutions and organizations, encouraging you to act hastily depending on the situation, or having frightening content that will give you anxiety. Of course, it doesn't have to be that way!

The simplest method to avoid falling victim to phishing (phishing attack) or spear-phishing (targeted phishing attack) is to click on the detail arrow next to the email to confirm the sending address is correct. In addition, there is an option which you have to verify the correctness of the addresses by examining the institution/organization/person that sent you an e-mail from the subdomain (eg: www) to the top-level domain (eg: com). For example: **myaccount.google.com--hackerdoma.in/account-recovery**

Usually, the first characters of the long links look quite reliable and they hide that you are directed to their servers with different parameters. Or they try to trick you with URL conversions. Tools such as 'URL decoder' can be used to analyze the complexity of URLs. If we are aware that each domain layer is equivalent to a filename, we will also gain awareness of fake sites that can be created by bypassing special characters when creating a filename. For example, although the following two URLs look exactly the same, they are different in terms of filename:
https://github.com/RaiDeiNz/awesome-iocs
https://github.com/RaiDeiNz/awesome‑iocs

When the second URL is examined (for example, it can be controlled by URL encoding), it should be noted that **%E2%80%90%** is used instead of the hyphen after the awesome name "-". Such bypasses are possible.

2-5-8 E-mail Fraud

With e-mail fraud, which is also a method similar to a phishing attack, cyber hackers can send you an e-mail from a different domain address, even though they do not have it. In e-mails with suspicious content that make you suspicious; To avoid such attacks, it is necessary to check the e-mail headers. With this method, all kinds of transactions that the e-mail went through until it reaches you are seen in detail. For this, the header display tools of the e-mail service you use should be checked. While you can access these features from your mailbox in Outlook, you need to use a different service for Gmail.

2-5-9 SMS Phishing Attack / Smishing

We mentioned that technology and the information sector are constantly developing/changing while explaining the subject with a chronological structure. Sms phishing attack(smishing) is a type of attack in which companies and people act with a different methodology developed by cybercriminals after they are more susceptible to e-mail phishing attacks.

We talked about the Caller ID Spoofing technique. This is a tool that makes your number look like someone else's number. In this way, the attacker can send you a message with the name registered in the phone book by imitating a number in your phone book. Or it can pretend to be an institution by faking the official number of an institution. The result is the same thing. They pretend to be someone else, sending you various links, asking you to click on them and take action. Some URLs, such as on a computer, can infect your phone with malware as soon as it is clicked. Or it can steal your identity or company information with a

fake link that looks like the real site of the institution.

3. EXTERNAL THREATS

3-1. Preamble

*According to the ' **Cloud Survey'** results, in most cases, external cybercrime has been committed to stealing core business content (data, etc). Trojan, worms, phishing, malware, etc. attacks are created to gain access to the target computer. A few cybercriminal groups, such as **Holmium** (also known as Elfin Team / APT33), carry out attacks on government institutions and organizations. The perspective of this type of cybercrime group is to teach a moral lesson or to take some form of revenge on the target firm. It may be possible that your company or industry is not threatened by these groups; but still under the target of individual hackers. In some cases, the main target of external attacks is to disclose or steal customer records. This is because as a result of this activity, personal information is sold on the Darkweb for a certain price.*

3-2. Definition

Malware, phishing, DDoS attacks, ransomware; are just a few of the attacks and methods hackers use externally to gain access to your site, software, or network. Part of a good cybersecurity firm's repertoire is the ability to deal with each of these issues and prevent external cybersecurity risks in whatever form. Once accessed, these cyber criminals extract information, sometimes staying inside the system for months. Most are never found and do not take action until a later date.

Since an organization will face an external attack rather than an internal attack, it is necessary to strengthen the environment (Network Perimeter) to keep hackers out.

3-3. External Threats

3-3-1. DDoS

It is an external threat known as Distributed Network Attacks or **Distributed Denial of Service** attacks. These types of attacks take advantage of certain capacity limits that apply to any network resource, such as the infrastructure that provides a company's web service. A cybercriminal attacking with the DDoS method sends multiple requests to the target web resource, aiming to exceed the capacity of the website and not work correctly by trying to process a large number of requests. DDoS attacks are often carried out using botnets.

Botnet: IP addresses have been compromised hardware (Zombie machines).

3-3-2. Session Hijacking

Html is a standard text markup language for building a website. As technology has developed, web contents have also been shaped, applications that require sessions and multi-tab pages have emerged. The username and password requested from you to access a website interface only gives you access for that moment and for that page (eg mypage.com/myhompage.html). Even when you refresh the page, you must have to login again. For this reason, the hyper-text transfer protocol (HTTP) introduced the concept of cookie in 1994. A cookie is a kind of identification file left on the computer by any website. Session ids and similar data are stored in cookie files. In this way, it is not necessary to log-in while refreshing the page or accessing different tabs(like mypage.com/myfolders) under the site.

But these cookies have a specific header and tail by default and your session information is the middle of this encrypted data. A cybercriminal, observing the change in data by creating different users, can act like any other user and log into the system by reversing the encryption on the part that has been changed. This includes the 'admin' ID, which is left by default.

(For example: eyJhZG1pbiJ9 this is a base64-encoded {"admin"} ID. And this is eyJ1c2VyIn0= a {"user"} ID. If you discover that the difference lies between the two quotes and you put the admin for the user, an admin cookie will be created.)

3-3-3. Drive-by Attack

Cybercriminals search for unsafe websites(eg: XSS) and insert a malicious script into the HTTP (ex: 404 page) or PHP code on those pages. This script can install the malware directly on the computer of someone visiting the site or take the form of IFRAME that redirects the victim to a site controlled by cybercriminals.

These types of attacks are called 'drive-by attacks' because the victim does not need to take any action. Just visiting the site is enough.

3-3-4. Password Attack

This attack vector is an external threat type that includes other attack vectors.

We can list these attacks as follows:

- #### a. Phishing

As we mentioned in internal threats, **phishing/identity hunting** is when a hacker pretending to be a trusted party sends you a fake email hoping to voluntarily disclose your

personal information. Sometimes they will redirect you to fake 'reset your password' screens; sometimes, the links you click infect your device with malware like keyloggers.

- ### b. Man-in-The-Middle Attack

Man-in-the-middle (MitM) attacks are when a hacker bridges two end connections which one is a compromised system. The attacker can record all the communication by putting his own web server in between, or he can observe it instantly. When the victim enters the username and password while logging into a system and presses the log-in button, this post request is transmitted to the remote server by first going to the attacker. Meanwhile, the attacker steals the victim's credential information.

- ### c. Brute Force Attack

The Brute Force attack type is the attempt to try multiple password and username combinations using a combo-list to find the victim's password. I would like to use the same analogy that I came across in one of the sources I worked on while preparing the article. If a single password were to be depicted with the 'key' which used to open a basic door, a brute force attack would be to use a 'battering-ram' for destruction. A hacker can try 2.18 trillion password/username combinations in 22 seconds.

- ### d. Dictionary Attack

Although a dictionary attack is relatively similar to a brute-force attack, the goal here is to get more precise results. An attacker who collects information about you on social media (for example, if you wrote the name of the animal in the description of your pet's picture you shared on Instagram), prepares a list of information such as date of birth, city of birth, pet name and license plate. With this information, it achieves its purpose with almost certain results.

- ### e. Credential Stuffing

Phishing attacks are done by trying the same information that was previously leaked from different sources, as in the case of the ‘kitapyurdu’. If you use the same or very close passwords, you may be a victim of these attacks.

- ### f. Keyloggers

Keylogger is malware that records every key pressed on the keyboard. This malware does not need to infect your computer. It can also work on websites with XSS vulnerabilities, directed at a log address. The external cyber attacker uses such attack vectors to capture the information of the users on the site.

3-3-5. Spear Phishing

A targeted phishing attack, unlike a normal phishing attack, is a type of attack in which fraudulent e-mails are sent to a certain group or sector.

3-3-6. Ransomware

Types of software, also known as Ransom-Blackmail-Bullying softwares, is a type of attack that is generally integrated with the name of ransomware. Ransom viruses are malicious software that demands ransom from users by blocking access to files on infected information systems. If the requested payment is not made, they will blackmail you by sharing your data on public forums. Institutions and organizations that do not want their trade secrets to be disclosed prefer to pay rather than reconciliation.

3-3-7. Malware

Malware is software used to disrupt the functions of computers and mobile devices, collect critical information, gain access to private computer systems, and display unwanted advertisements.

3-3-8. Malvertising

Malvertising is malicious software that applies social engineering to you, even if it is not live, that attacks your emotional vulnerability to achieve this. Some web applications accept all kinds of advertisements even if it's evil. It collects data from your credential and cookie information on the sites and gives you targeted warnings. For example, if it shows itself as Kaspersky and your computer is infected with a virus, it may ask you to hurry and click the "Quick Scan" button. While doing this, it can gain credibility by saying that it is caused by your HTTP header information, the browser model and version you are using, and a vulnerability in that version. Present-day, these attacks are frequently seen on popular social media sites such as Facebook, Twitter, youtube, google, etc. Cyber attackers can get your attention by advertising targeted for you (and they are doing it cheaply). These sites are already processing your data and you know it. (Even if most people say "Oh dear, what are they going to do with my data? I don't care!")

3-3-9. APT

Nation cyber militants and cyber intelligence hackers divide into certain groups in many countries and make organized plans for the attacks they aim to carry out in the long term. Advanced persistent threat (APT) groups gain access to a system by constantly using covert and advanced hacking techniques to create devastating consequences. Some of these groups, along with details such as the tactics, techniques, and procedures they use, are shared on

resources such as MITRE for those who want to obtain intelligence about them.

3-4. Methods of Protection from External Threats

In addition to the pieces of training in Article 2-5, individuals and institutions are required to have regular penetration tests for the method of protection from external threats. Even if this institution is an institution providing penetration testing service, it is recommended to obtain the same service from another institution.

- In line with these tests, vulnerabilities in the system can be detected and the necessary infrastructure and modules can be reviewed and updated.
- Some security measures apply to external threats as well as internal threats. Another example of this is the use of external memory. USB Flash drives with high storage capacity can be made more believable by adding objects such as keychains prepared with the identity information of a person in the targeted institution as a result of tracking and detection on social media and can be left near the house. Deceiving an employee who works remotely and connects to the company from his home by these hackers can endanger the entire company network. To prevent external threats, it is necessary to be sensitive to such attacks.
- Persons such as a repairman, plumber, or courier who come to the company/institution should not be admitted without correct identification and verification. If possible, it should not be taken inside.
- The company should make regular data backups.
- The company must configure its servers against DDoS attacks and multiple requests don't be received from the same source at regular intervals. In case of repetition of the same request, an infrastructure should be prepared in which the client is blocked. If a large number of requests have been sent to the server(from the same or different clients/sources) in a short time, they must be queued.
- Cloud computing systems should be used.
- Attention should be paid to DevOps, CI/CD issues. Public API key or configuration errors should not be made.

4. PEOPLE WHO MAY BE TARGET OF INTERNAL AND EXTERNAL THREATS

Almost everyone is the target of internal and external threats. Generally, cybercriminals target companies/institutions and organizations that are difficult for them for larger-scale gains or high prestige. However, almost anything can be a target, from the individual, the smallest building block of the society, to the countries as well. Let's list:

4-1. Persons

Any person can be a goal to be achieved as part of a larger plan.

4-2. Institutions and Companies

Google,Facebook, xxx.gov.*, xxx.mil.*

4-3. Countries

A cybercrime group targeting the infrastructure services that are managed with systems such as SCADA can take over these systems and harm countries through their management controls.

4-4. Unions and Groups

In addition to the fact that groups such as Anonymous and RedHack target each other among themselves, a hacktivist group with a racist policy can target communities that are not their own.

4-5. World and Beyond

Today, Mars is a planet planned to be colonized. Apart from that, we regularly send vehicles into space. The first imagable of these are the satellites. As a communication superstructure, satellites are used for communication and GPS systems. Apart from this, satellites with advanced lenses in terms of zooming can be targets for different types of intelligence purposes.

REFERENCES

Source for the operation diagram of the subject between items 1-1 1-3: karel.com

Video source for the topic 1-1 1-3 : Youtube

Source for item 1-2-1 : iso.org

Source for item 1-2-2 : Wikipedia

Source for item 1-2-3 : Wikipedia

Source for item 1-2-4 : Wikipedia

Source for item 2-4 : varonis.com

Source for item 2-5 : keepnetlabs.com

Source for article 3-3-1 : Kaspersky

Source for Article 3-3-2 : Wikipedia

Source for article 3-3-3 : Kaspersky

Source for item 3-3-4 : onelogin.com

Source for article 3-3-6 : Wikipedia

Source for Article 3-3-7 : Wikipedia

Source for Article 3-3-8 : Wikipedia

Source for article 3-3-9 : Kaspersky

Source for the general topic concept: 1. cloudcodes.com 2. ermprotect.com